

JMPM

Guia de Segurança - RPO Bytecode Injector

DATA

30/09/2026

ARQUIVO

SECURITY-GUIDE.md

Visão Geral

Este documento descreve as considerações de segurança do sistema RPO Bytecode Injector.

Ameaças Identificadas

1. Vazamento de Chaves de Criptografia

Risco: Alta

Classificação: Dados Sensíveis

As capturas contêm chaves de criptografia efêmeras que devem ser tratadas como segredos.

Mitigação

```
# Nunca commitar arquivos de captura
echo "capture*.json" >> .gitignore
echo "*.rpo" >> .gitignore

# Limpar após uso
rm -f /tmp/capture*.json
rm -f /tmp/*.rpo
```

2. Injeção de Código Malicioso

Risco: Média

Classificação: Integridade

Bytecodes maliciosos podem comprometer o sistema Protheus.

Mitigação

- Validar origem dos bytecodes
- Usar assinaturas digitais
- Isolar em sandbox

3. Corrupção de RPO

Risco: Alta

Classificação: Disponibilidade

RPOs corrompidos podem tornar o sistema inoperante.

Mitigação

- Manter backups antes de modificações
- Validar integridade pós-injeção
- Testar em ambiente controlado

Tratamento de Segredos

Capturas JSON

Arquivos de captura contêm:

- Chaves simétricas (16 bytes)
- IVs (8-16 bytes)
- Plaintexts (podem conter dados sensíveis)

Protocolo:

1. Gerar em ambiente isolado
2. Usar imediatamente
3. Destruir após uso
4. Nunca persistir em versão

Códigos Fonte

Fontes AdvPL podem conter:

- Lógica de negócio sensível
- Dados de integração
- Credenciais embutidas

Protocolo:

1. Revisar antes de compilar
2. Remover hardcoded secrets
3. Usar variáveis de ambiente

Checklist de Segurança

Antes da Compilação

- ☐ Ambiente isolado (Docker)
- ☐ Hook validado
- ☐ Fontes revisadas
- ☐ Backups criados

Durante Processamento

- ☐ Captura lida em memória
- ☐ Chaves não persistidas
- ☐ Logs sem dados sensíveis

Após Processamento

- ☐ Capturas deletadas
- ☐ Temporários limpos
- ☐ Logs auditados

Auditoria

Logs do Sistema

```
# Verificar logs do hook
docker exec protheus-custom cat /tmp/rpo_key_hook.log 2>/dev/null || echo "Sem log"

# Verificar processos
docker exec protheus-custom ps aux | grep rpo
```

Validação de Integridade

```
# MD5 do RPO original
md5sum custom.rpo

# MD5 do RPO injetado
md5sum injected.rpo

# Verificar estrutura
./advplc rpo info injected.rpo
```

Response to Incidents

Cenário 1: RPO Corrompido

```
# 1. Restaurar backup
cp custom.rpo.backup custom.rpo

# 2. Verificar
./advplc rpo info custom.rpo

# 3. Reaplicar se necessário
./advplc rpo inject custom.rpo nova_captura.json
```

Cenário 2: Vazamento de Chaves

```
# 1. Identificar exposição
find /tmp -name "capture*.json" -exec ls -la {} \;

# 2. Destruir
rm -f /tmp/capture*.json

# 3. Regenerar chaves
# (nova compilação gera novas chaves efêmeras)
```

Cenário 3: Code Injection Suspeita

```
# 1. Isolar
docker stop protheus-custom

# 2. Investigar
strings bytecode.bytecode | grep -i "exec\\|system\\|eval"

# 3. Remover
rm -f bytecode.bytecode
```

Compliance

LGPD

- Dados pessoais em capturas devem ser tratados como dados sensíveis
- Right to erasure: destruir capturas sob demanda
- Accountability: registrar processamento

ISO 27001

- A.8.24: Gestão de segredos
- A.8.9: Configuração segura
- A.8.16: Monitoramento

Referências

- OWASP Top 10
- [LGPD - Lei 13.709/2018]
- [ISO 27001:2013]